

RAPPORT D'INCIDENTS

CYBERSÉCURITÉ — COMPILATION Q3 2024

Analyse multi-entités — Secteurs: Santé, Défense/Identité numérique, Services Cyber

Réf: CSIRT-2024-Q3-COMPILATION-007
Émetteur: SOC Central – Cellule Threat Intelligence
Date: 2024-09-18T14:32:00Z
Distribution: COMEX + RSSI uniquement
Niv. confidentialité: C3-SECRET ENTREPRISE

EXECUTIVE SUMMARY

& ALERTE CRITIQUE: 3 incidents majeurs identifiés au cours du trimestre Q3-2024, dont 1 compromission confirmée avec exfiltration de données de santé (RGPD Art. 33 — notification CNIL effectuée dans les 72h). Impact financier estimé: 4,2M€ (coûts directs) + 12-18M€ (coûts indirects sur 24 mois).

Ce rapport compile les incidents cybersécurité significatifs survenus entre le 01/07/2024 et le 30/09/2024, affectant trois entités du périmètre de surveillance:

DRAFT — validation RSSI en attente

- Entité A — Groupe Hospitalier Sainte-Marguerite (GHSM): Établissement de santé multi-sites, ~800 collaborateurs, secteur Healthcare.
Incident: Ransomware (LockBit 3.0 variant) avec chiffrement partiel du SI clinique et exfiltration de 47 Go de données patients.
- Entité B — Thales DIS (Digital Identity & Security): Division cybersécurité/identité numérique du groupe Thales.
Contexte: Préparation conformité NIS2 (échéance transposition nationale: 17 octobre 2024). Audit de maturité cyber.
- Entité C — Orange Cyberdefense (OCD): Filiale cybersécurité d'Orange, ~3 000 collaborateurs, prestataire SOC/CERT.
Rôle: Intervenant CERT sur l'incident GHSM + benchmark concurrent sur le marché MSSP français.

Structure du rapport: §1 Executive Summary (ce chapitre) ! §2 Chronologie détaillée ! §3 Analyse technique (IOCs, TTPs MITRE ATT&CK) ! §4 Impact et évaluation des dommages ! §5 Recommandations et plan de remédiation ! Annexes (A: IOCs complets, B: logs SIEM, C: communications de crise).

MÉTRIQUES SOC — Q3 2024

Alertes SIEM traitées	847 293
Incidents qualifiés (L1/L2)	4 812
Incidents confirmés (L2/L3)	287
Incidents critiques (P1/P2)	11
Incidents avec exfiltration	3
MTTD (Mean Time To Detect)	4h 23min
MTTR (Mean Time To Respond)	18h 47min
Faux positifs (taux)	94,3%
Règles SIEM actives	12 847
Sources de logs intégrées	342
Agents EDR déployés	28 400

STACK TECHNIQUE DÉPLOYÉE

- SIEM: Splunk Enterprise Security 7.3 + Elastic SIEM 8.11
- EDR: CrowdStrike Falcon Insight (v6.58) / SentinelOne Singularity
- XDR: Palo Alto Cortex XDR Pro (intégration XSOAR)
- NDR: Vectra AI (Cognito Detect 8.x)
- SOAR: Splunk SOAR (ex-Phantom) + TheHive 5
- Threat Intel: MISP 2.4, OpenCTI 5.12, Anomali ThreatStream
- Zero Trust: Zscaler ZPA + Okta Identity Engine
- OT Security: Claroty xDome (IEC 62443 compliance)
- Vuln Mgmt: Qualys VMDR + Tenable.io
- Conformité NIS2: Plateforme propriétaire "NIS2-Ready™"

Les métriques SOC incluent les 3 entités surveillées. MTTD/MTTR calculés sur incidents P1-P3 uniquement.
TLP:AMBER — Ce document ne doit pas être partagé en dehors des destinataires nommés.

§2. CHRONOLOGIE DÉTAILLÉE — INCIDENT GHSM

P4/INFO	2024-08-12 02:17:43 UTC Première connexion RDP suspecte détectée sur GHSM-SRV-DC02 (10.42.1.12) depuis IP 185.220.101.xxx (TOR exit node). Alerte SIEM #847201 – auto-classée P4 (faible). Agent EDR en mode "detect-only" sur ce segment (erreur de config identifiée post-incident).
P3/WARN	2024-08-12 03:44:12 UTC Mouvement latéral détecté: GHSM-SRV-DC02 !' GHSM-SRV-APP01 (10.42.2.5) via PsExec. Credential harvesting confirmé (Mimikatz variant – hash NTLM du compte svc_backup exfiltré). Alerte SIEM #847209 – escaladée P3 mais non traitée (équipe SOC en sous-effectif nuit du 11-12 août, période estivale).
P1/CRITICAL	2024-08-12 06:15:00 UTC Début d'exfiltration via tunnel DNS (iodine) vers C2 identifié: data-sync.healthcloud[.]xyz (résolu vers 91.215.85.xxx – hébergeur bulletproof, AS394711). Volume estimé: 47 Go sur 8h (données patients: DME, comptes-rendus opératoires, imagerie DICOM). Alerte NDR Vectra – score: 87/100 (critique).
P1/CRITICAL	2024-08-12 08:30:00 UTC SOC L2 prend connaissance des alertes accumulées. Escalade immédiate P1. Activation du plan de réponse à incident (PRI-GHSM-v3.1). Contact CERT-FR (ANSSI) à 09:15.
P1/CRITICAL	2024-08-12 14:00:00 UTC Déploiement ransomware LockBit 3.0 (variant custom, anti-EDR packer). Chiffrement de 340 VMS sur 812 (41,9%). Systèmes cliniques impactés: SIH (Système d'Information Hospitalier), PACS (imagerie), GAM (gestion administrative). Note de rançon: 2.4M€ en BTC.
RESPONSE	2024-08-12 15:30:00 UTC Orange Cyberdefense (CERT OCD) dépêché sur site. Équipe de 6 analystes (2 forensic, 2 malware RE, 1 CTI, 1 crisis comm). Début du confinement réseau – isolation des VLANs critiques.
REMEDIATION	2024-08-13 – 2024-08-19 Phase de remédiation: restauration depuis backups (RPO: -36h, RTO atteint en 7j vs SLA de 4h pour systèmes critiques). 12 VMS non restaurables – reconstruction complète nécessaire. Coût estimé phase 1: 1,8M€.

§3. ANALYSE TECHNIQUE — MITRE ATT&CK MAPPING

Tactic	Technique ID	Technique	Procedure (observée)	Détection
Initial Access	T1133	External Remote Services	RDP brute-force via TOR (port 3389/tcp)	Alerte SIEM rule#4421
Execution	T1059.001	PowerShell	Encoded PS commands (base64) for payload staging	EDR — process tree
Persistence	T1053.005	Scheduled Task	Tâche planifiée "WindowsUpdate_Svc" — every 4h	Sysmon EventID 1
Priv. Escalation	T1003.001	LSASS Memory	Mimikatz variant (custom packer, SHA256: a4f8...)	CrowdStrike detect
Lateral Movement	T1021.002	SMB/Windows Admin	Psexec + pass-the-hash (NTLM svc_backup)	NDR Vectra score 87
Exfiltration	T1048.003	Exfil Over DNS	iodine tunnel !' healthcloud[.]xyz (47 Go)	NDR + DNS analytics
Impact	T1486	Data Encrypted	LockBit 3.0 — 340/812 VMs chiffrées (41,9%)	Volume encryption alert

```
INDICATEURS DE COMPROMISSION (IOCs) – EXTRAIT

# IP Addresses (C2 infrastructure)
185.220.101.34 | TOR exit node | First seen: 2024-08-12T02:17Z | Confidence: HIGH
91.215.85.142 | Bulletproof hosting | C2 callback (DNS) | Confidence: HIGH
45.153.160.12 | VPS (NL) | Secondary C2 (HTTPS) | Confidence: MEDIUM

# Domains
data-sync.healthcloud[.]xyz | C2 domain (DNS tunnel) | Registered: 2024-07-28
update-service.msftcloud[.]top | Payload staging | Registered: 2024-08-01

# File Hashes (SHA-256)
a4f8e2c1d7b3f9...48e2b7d903ef | Mimikatz variant (packed) | VT: 23/72
c91b0ef23a7d84...f12e8c4a0b67 | LockBit 3.0 payload | VT: 54/72
7e2f1a8b3c4d56...9a0e1b2c3d4f | iodine DNS tunnel client | VT: 12/72

# YARA Rule: rule LockBit3_Custom_Packer { meta: author="SOC-TI" ... strings: $mz="MZ" $s1={4C 6F 63 6B} ... }
```


§5. RECOMMANDATIONS & PLAN DE REMÉDIATION

CRITIQUE

REC-001: Reconstruction complète du SI GHSM

Échéance: 2024-12-31

Le SI du GHSM doit être considéré comme intégralement compromis. Recommandation: reconstruction from scratch selon architecture zero-trust. Budget estimé: 3,2M€ sur 18 mois. Prestataires short-listés: Orange Cyberdefense (CERT + rebuild), Capgemini (infrastructure), Thales DIS (HSM/PKI pour identités).

HAUTE

REC-002: Déploiement EDR/XDR unifié (toutes entités)

Échéance: 2025-03-31

Remplacement de la mosaïque EDR actuelle par une plateforme XDR unifiée. Évaluation en cours: CrowdStrike Falcon Complete vs Palo Alto Cortex XDR Pro vs SentinelOne Singularity Complete. Critères: intégration SIEM Splunk, couverture OT (IEC 62443), capacité SOAR native.

HAUTE

REC-003: Conformité NIS2 — audit gap analysis

Échéance: 2024-10-17

Mandater un audit NIS2 complet pour les 3 entités avant le 17/10/2024. L'audit doit couvrir: gouvernance (Art. 20-21), notification d'incidents (Art. 23), supply chain security (Art. 22), et les mesures techniques minimales (Annexe II). Prestataires qualifiés ANSSI (PASSI): Wavestone, Deloitte Cyber, Orange Cyberdefense.

MOYENNE

REC-004: Exercice de crise cyber (tabletop + red team)

Échéance: 2025-06-30

Organiser un exercice de crise cyber tri-annuel impliquant COMEX + équipes opérationnelles. Scénario recommandé: attaque supply-chain via fournisseur Tier-2 compromis. Inclure simulation de communication de crise (RGPD/CNIL + médias + patients). Budget: ~120k€/exercice.

MOYENNE

REC-005: Segmentation réseau OT/IT — IEC 62443

Échéance: 2025-09-30

Implémenter une segmentation stricte OT/IT conforme IEC 62443 (zones & conduits) pour les environnements hospitaliers (équipements biomédicaux connectés). Déployer Claroty xDome ou Nozomi Guardian pour la visibilité OT. Priorité: dispositifs médicaux classe IIb/III.

ANNEXES (non incluses dans cette version — disponibles sur demande auprès du SOC):

Annexe A: Liste complète des IOCs (487 indicateurs) — format STIX 2.1 / OpenIOC

Annexe B: Logs SIEM bruts — période 2024-08-10 à 2024-08-20 (2,3 Go compressé)

Annexe C: Rapport forensique complet — Orange Cyberdefense CERT (147 pages)

Annexe D: Communications de crise — emails, communiqués presse, notifications CNIL/ANSSI

Ce document est soumis au protocole TLP:AMBER+STRICT. Toute diffusion non autorisée constitue une violation du RGPD et de la politique de sécurité de l'information.

Réf: CSIRT-2024-Q3-COMPILATION-007 | Classification: C3-SECRET ENTREPRISE | Émetteur: SOC Central | Date: 2024-09-18